

Chiffrement des données

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	3
Les concepts du chiffrement.....	3
Terminologie du chiffrement.....	3
Attaque contre le chiffrement.....	4
Chiffrement à clé privée.....	4
Chiffrement à clé publique.....	5
Signatures numériques.....	6
Chiffrement du courrier électronique.....	6
Installation.....	7
Création de clés.....	7
Gestion des clés.....	9
Utilisation de GPG.....	11
Chiffrement du système de fichiers - Windows.....	13
Principe de fonctionnement.....	13
Activation du cryptage de fichier.....	14
L'utilitaire cipher.....	14
Chiffrement du système de fichiers - Linux.....	15
Installation de TCFS.....	15
Utilisation de TCFS.....	16
Kerberos.....	16
Terminologie Kerberos.....	17
Fonctionnement de Kerberos.....	17
Configuration d'un serveur Kerberos 5 – Windows.....	18

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL.

Permission vous est donnée de distribuer, modifier des copies de ce document tant que cette note apparaît clairement.

Configuration d'un serveur Kerberos 5 – Linux.....	18
Références.....	19

Introduction

Le chiffrement est un outil de sécurité important : les mécanismes de chiffrement aident à protéger la confidentialité et l'intégrité de l'information ou à identifier la source de l'information. Ce chapitre est destiné à fournir les éléments de base pour comprendre ce qu'est le chiffrement, ainsi que divers outils permettant la mise en application de différents mécanismes de chiffrement.

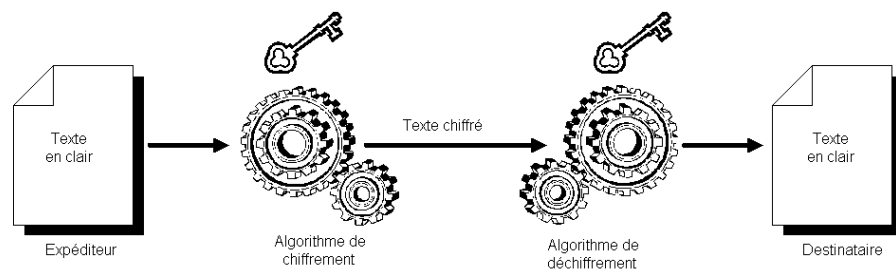
Les concepts du chiffrement

Le chiffrement consiste simplement à dissimuler de l'information de telle sorte qu'elle soit cachée aux individus non autorisés tout en étant accessible aux personnes autorisées. Le concept est simple mais sa mise en application se révèle difficile. À l'aide du chiffrement, nous pouvons protéger en partie les trois attributs de sécurité suivants :

- la confidentialité;
- l'intégrité;
- la responsabilité.

Terminologie du chiffrement

Le schéma de l'opération de chiffrement est présenté à la figure suivante.



Les termes relatifs aux composants utilisés pour les opérations de chiffrement et de déchiffrement sont :

- **Texte en clair** : l'information dans sa forme originale.

- **Texte chiffré** : l'information rendue incompréhensible par l'algorithme de chiffrement.
- **Algorithme de chiffrement** : fonction mathématique qui est utilisée pour changer le texte en clair en texte chiffré.
- **Clé** : ensemble de données, utilisé par l'algorithme de chiffrement, qui permet de transformer le texte en clair en texte chiffré.
- **Chiffrement** : processus qui consiste à changer le texte en clair en texte chiffré.
- **Déchiffrement** : processus qui consiste à changer le texte chiffré en texte en clair.

La cryptographie est la science qui étudie les principes, méthodes et techniques mathématiques reliés aux aspects de sécurité de l'information telles la confidentialité, l'intégralité des données, l'authentification d'entités et l'authentification de l'originalité des données.

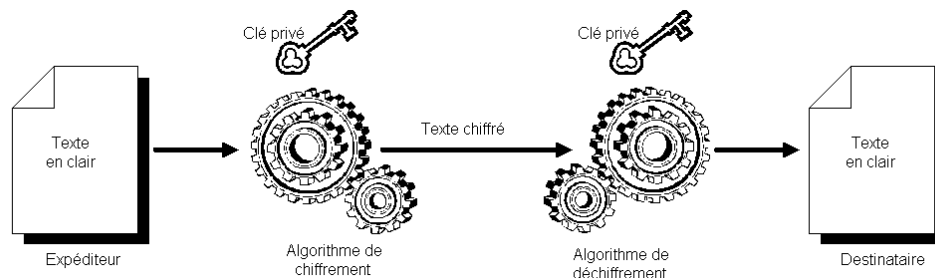
Attaque contre le chiffrement

Les systèmes de chiffrement peuvent être attaqués de trois méthodes :

- via les points faibles de l'algorithme;
- par la force brute contre la clé;
- à travers les points faibles de l'environnement du système.

Chiffrement à clé privée

Les systèmes de chiffrement à clé privée, appelé aussi système de cryptage symétrique, utilise la même clé pour chiffrer et déchiffrer l'information. La figure suivante présente le principe de fonctionnement du chiffrement à clé privée.



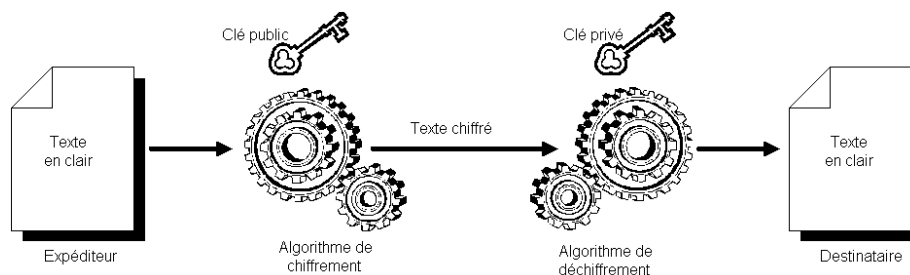
L'expéditeur et le destinataire de l'information doivent avoir la même clé. Le chiffrement à clé privée assure la confidentialité de l'information. Seuls ceux qui possèdent la clé peuvent déchiffrer le message. L'intégrité de l'information est aussi assurée puisque toute modification durant la transmission sera détectée lors du chiffrement; le chiffrement ne s'effectuera pas correctement.

En général, le chiffrement à clé privée est rapide et facile à mettre en œuvre. Voici un exemple de chiffrement :

Texte en clair	S	E	N	D	H	E	L	P
Lettres changées en nombre	19	5	14	4	8	5	12	16
One-Time Pad	7	9	5	2	12	1	0	6
Addition du texte en clair et OTP	26	14	19	6	20	6	12	22
Texte chiffré	Z	N	S	F	T	F	L	V

Chiffrement à clé publique

Le principe de fonctionnement du chiffrement à clé publique, aussi appelé le chiffrement asymétrique, est présenté à la figure suivante. Ce chiffrement implique une paire de clés : une clé publique et une clé privée. La clé publique est connue de tous alors que la clé privée est tenue secrète par le propriétaire de la paire de clé. Une caractéristique de ce système est qu'à partir d'une clé il est impossible de calculer la seconde.

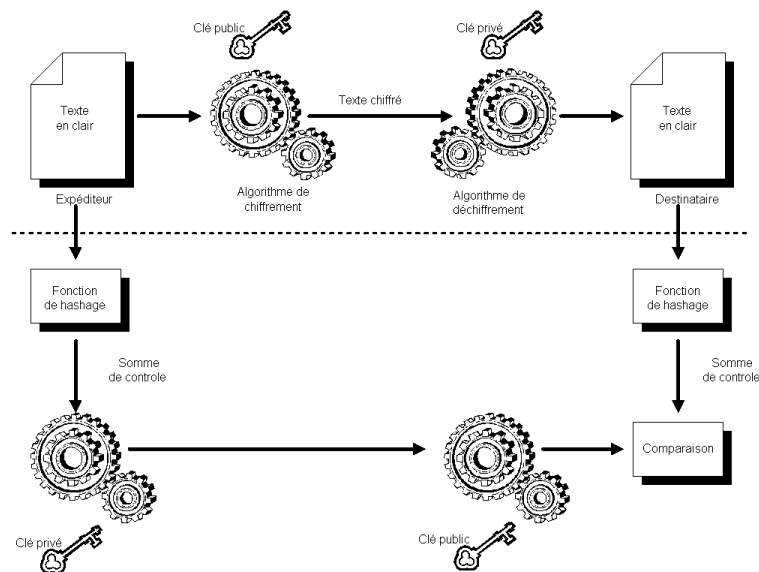


Pour envoyer un texte chiffré à un destinataire, il faut utiliser la clé publique de ce destinataire pour chiffrer le texte. Une fois reçu, le destinataire utilise sa clé privée correspondante pour déchiffrer le message.

Contrairement au chiffrement à clé privée, le chiffrement asymétrique requiert beaucoup de calcul et donc n'est pas recommandé pour de grandes quantités d'informations.

Signatures numériques

Les signatures numériques ne sont pas des images numériques de signatures écrites à la main. Il s'agit plutôt d'une forme de chiffrement qui assure l'authentification de l'information électronique. La signature numérique permet de s'assurer que l'information n'a pas été modifiée après qu'elle a été déchiffrée. La figure suivante montre le déroulement de cette opération.



Chiffrement du courrier électronique

Dans cette section, GPG (GNU Privacy Guard) est présenté. GPG est une implantation « Open Source » de la méthode PGP (Pretty good Privacy) de la « Free Software Foundation ». Bien que GPG permette le chiffrement de plusieurs types de données, le chiffrement du courrier électronique est l'utilisation la plus fréquente de cet outil.

GPG utilise une méthode de chiffrement asymétrique, une clé publique et une clé privée sont donc nécessaires pour l'utilisation de GPG. La clé publique circule aussi largement que possible et peut même être enregistrée dans des bases de données de clés publiques. La clé privée est une clé personnelle qui doit être gardée secrète.

Installation

« GNU Privacy Guard » (GPG) peut être téléchargé à partir du site www.gpg.org. Plusieurs distributions offrent des paquets pré-construits de GPG, dont Red Hat.

Création de clés

Avant de pouvoir envoyer ou recevoir des données chiffrées, une paire de clés doit être générée. La génération de clé s'effectue en utilisant l'option - - *gen-key* de l'utilitaire *gpg*. Voici un exemple :

```
gpg --gen-key
gpg (GnuPG) 1.2.1; Copyright (C) 2002 Free Software Foundation, Inc.
This program comes with ABSOLUTELY NO WARRANTY.
This is free software, and you are welcome to redistribute it
under certain conditions. See the file COPYING for details.

Please select what kind of key you want:
  (1) DSA and ElGamal (default)
  (2) DSA (sign only)
  (5) RSA (sign only)
Your selection? 1
DSA keypair will have 1024 bits.
About to generate a new ELG-E keypair.
      minimum keysize is 768 bits
      default keysize is 1024 bits
      highest suggested keysize is 2048 bits
What keysize do you want? (1024)
Requested keysize is 1024 bits
Please specify how long the key should be valid.
    0 = key does not expire
    <n> = key expires in n days
    <n>w = key expires in n weeks
    <n>m = key expires in n months
    <n>y = key expires in n years
Key is valid for? (0)
Key does not expire at all
```

```

Is this correct (y/n)? y

You need a User-ID to identify your key; the software constructs the
user id

from Real Name, Comment and Email Address in this form:

    "Heinrich Heine (Der Dichter) <heinrichh@duesseldorf.de>"

Real name: Stephane Gill
Email address: poil@poil.is-a-geek.net
Comment: Enseignant
You selected this USER-ID:

    "Stephane Gill (Enseignant) <poil@poil.is-a-geek.net>"

Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? o
You need a Passphrase to protect your secret key.

We need to generate a lot of random bytes. It is a good idea to
perform some other action (type on the keyboard, move the mouse,
utilize the disks) during the prime generation; this gives the random
number generator a better chance to gain enough entropy.
+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++
+.++++>....<+++++..>+++++.....<..+++++.....+++++
We need to generate a lot of random bytes. It is a good idea to
perform some other action (type on the keyboard, move the mouse,
utilize the disks) during the prime generation; this gives the random
number generator a better chance to gain enough entropy.
+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++.+++++
+>+++++.....>+++++.....+++++^^^
gpg: /root/.gnupg/trustdb.gpg: trustdb created
public and secret key created and signed.
key marked as ultimately trusted.

pub 1024D/A4047BC4 2003-10-29 Stephane Gill (Enseignant)
<poil@poil.is-a-geek.net>
    Key fingerprint = 1F6E E1AE F1D6 CF5E A921 8FAF 8B1B B7BD A404
7BC4
sub 1024g/AF5455EF 2003-10-29

```

S'il s'agit de la première utilisation de GPG utiliser d'abord la commande suivante pour créer le répertoire `$HOME/.gnupg` :

```
gpg --gen-key
```

Gestion des clés

De nombreuses options de l'utilitaire gpg permettent de rassembler, d'utiliser et de valider des clés. Ces outils sont essentiels pour travailler avec les clés. Cette section présente quelques-uns de ces outils.

Lister les clés

Pour obtenir une liste des clés de votre trousseau (keyring) avec les noms et adresses de courriel des propriétaires la commande suivante est utilisée :

```
gpg - -list-keys
/root/.gnupg/pubring.gpg
-----
pub  1024D/A4047BC4 2003-10-29 Stephane Gill (Enseignant)
<poil@poil.is-a-geek.net>
sub  1024g/AF5455EF 2003-10-29
```

Chaque entrée de la liste représente une clé publique qui peut être utilisée pour chiffrer des données.

Exportation de clés

Votre clé publique doit être envoyée à un destinataire pour que celui-ci puisse envoyer un message chiffré. La commande suivante permet d'exporter la clé publique de l'utilisateur *poil* vers le fichier *macle.gpg*.

```
gpg --export poil@poil.is-a-geek.net > macle.gpg
```

La clé publique réservée à `poil@poil.is-a-geek.net` est maintenant stockée dans le fichier `macle.gpg` et peut être diffusée. L'utilisation de l'option `-a` permet d'exporter les clés en format ascii et de les inclure dans un courriel. Voici un exemple :

```

pgp -a --export poil@poil.is-a-geek.net > macle.gpg
more macle.gpg
-----BEGIN PGP PUBLIC KEY BLOCK-----
Version: GnuPG v1.2.1 (GNU/Linux)

mQGIBD+gLpWRBACmdhHN+hChNHLCf40Ck2Wn7jXqVacvhttraMzxmhENkZojes8St
QqFIq0yJCKhKfuWQt+xdt4s6k60e/YjPhyKUUJ5AeXHK5Hh96GizVtqj/iylCjhX
czGANjawe3SzggiOGA43iSVG4+Hd2J+EXpodnuJ/gG/r+zxOq/Ds8eTNXwCgnv7b
HO3ZynYc6pMTBDxpP0XmOfkD/1XKfdL3Dhisb0X01Tk3HqwBkDaPl2yEWiJfAFsx
/X8spsvin30hpOGhemc7ZbvtIQ+VuuHQpQ3Wh3Dy9+FYcCptyN5jCqdR6iYJiIH9
ARuN+mYiQYUmIB6qokLWp2f4PpcAmiWU0KBknTii87ofXSb3djhrHc9at4o6VCAz
0QPyBACa7Fdyy8MFxheV+/Xy7ZKpajadWXqJPesE0NyKQxl5bwx7Y/66/HcVoXR
jE9nRs2qRfteAH3ElpMU3F1bG4g3osz1yp5g0FUNK41tb8iRuJdpPcaz8bm5AbQ7
Td0ybK+9sMFjVwPLFA8Mz0v7CtR8pIelXHNaoawT+SAoofR+aUrQ0U3RlcGhhbmUg
R2l5bCAoRW5zZWlnbmFudCkgPHBvaWwAcG9pbC5pcy1hLWdlZWsubmV0PohZBBMR
AgAZBQI/oCz8BAShAwIDFQIDAxYCAQIEAQIXgAAKCRCLG7e9pAR7xMTxAJ46K3LP
9DO93kG3RYI9Nh+X65Ue+QCfU648VA1KZpt+70jPuS+3uVJKbpy5AQ0EP6AtDBAE
ANpssBfUQbEHNFNQs7P+2DataS1vxBgbkYr5fpXhL5l3gZkBzGau6FeasmJwEXE
3T4h5AsGzofzj/YmBdJsMH7mM86Sh/rqXG4IR9F45fiJpl7Fmd86eNrv5BpRhUdt
H6cQjjEsWsbk94+Sx30m2LYbn6lvf21PRrQI6qfi3BbbAAMFA/4ulghTQU57yumg
63KJuxuB14qGEIXC7jPrS2vMH3ESIQPd55HhRnflZeuDjiLN5Z7cwDBx9/C9+3bU
FuR6lhyEJcg5k22uYG799/EHPKo0GDm40Otl+1uKk9QCQBJ0eEKyazG6h+t2QeiG
1lekiU0tNTCKMLbNEMAH4ninnudQgIhGBBgRagAGBQI/oC0MAAoJEIsbt72kBHvE
Pq0An1hXln9cir8C3XW7vuW4Y/agBSRJAJ9LRA7cGv+IowpyFeU1XeMRInND7Q==
=Yvjp
-----END PGP PUBLIC KEY BLOCK-----

```

Importation de clés

Les clés publiques reçues dans un fichier peuvent être ajoutées à un porte-clés à l'aide de la commande suivante :

```
pgp --import LaCleDePoil.gpg
```

Les signatures et la confiance

Lorsqu'une nouvelle clé publique est reçue et qu'aucune information n'est disponible pour témoigner d'un niveau de confiance relatif à la clé, il faut réaliser une empreinte de la clé. Soit l'exemple suivant :

Poil vient d'envoyer une clé publique et aucune information de confiance n'est disponible pour cette clé. La première opération à effectuer est de faire une empreinte de cette clé à l'aide de la commande suivante :

```
gpg --fingerprint poil@poil.is-a-geek.net
```

Cette empreinte, générée à partir des données de la clé, est unique. Il faut par la suite contacter poil et vérifier :

- si poil a bien envoyé une clé;
- quel est l'empreinte de sa clé publique.

Si l'information concorde, il faut signer la clé avec la commande :

```
gpg --sign-key poil@poil.is-a-geek.net
```

Il est aussi possible d'obtenir une liste des signatures associées aux clés publiques d'un trousseau personnel en utilisant :

```
gpg --check-sigs poil@poil.is-a-geek.net
```

Plus la liste des signatures est longue, plus une clé est supposée être valide. Il peut arriver qu'une clé ne comprenne qu'un petit nombre de signatures, ou même une seule, provenant d'un destinataire dont l'identité est mise en doute. Pour combattre cette dilution de confiance, il est souhaitable d'indiquer le niveau de confiance à accorder à un propriétaire de clé.

```
gpg --edit-key poil@poil.is-a-geek.net
```

Utilisation de GPG

Dans cette section, les utilitaires de chiffrement, de déchiffrement et de signature des données sont présentés

Signature de données

La signature de données est utilisée par un expéditeur de façon à s'assurer que le destinataire puisse valider l'intégrité des données. C'est en utilisant sa clé privée que l'expéditeur signe les données. La manière la plus simple de signer des données est d'utiliser la commande :

```
gpg --clearsign lemessage.txt
```

une signature comme celle-ci sera créée dans le fichier *lemessage.txt.asc*.

```
more lemessage.txt.asc
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA1

Voici un fichier de test.
Signature de donnees.
Chiffrement

-----BEGIN PGP SIGNATURE-----
Version: GnuPG v1.2.1 (GNU/Linux)

iD8DBQE/oc5Pixu3vaQEe8QRAuj8AJ9Zg/6JQwashXYC2DTnpzcxpftCKwCfVGV8
obyAEzj/MOwn7wvq1y33QXU=
=hSBk
-----END PGP SIGNATURE-----
```

Lorsque le message contenant cette signature est reçu, le destinataire peut vérifier l'intégrité du message à l'aide de la commande :

```
gpg --verify message.txt.asc
```

Une signature vérifiée indique que le message provient de l'expéditeur annoncé et qu'il n'a pas été modifié.

Chiffrement des données

Le chiffrement d'un fichier en ayant recours à la clé publique du destinataire poil se fait de la façon suivante :

```
gpg -r poil@poil.is-a-geek.net -a - -encrypt message.txt
```

le résultat du chiffrement sera écrit dans le fichier *message.txt.asc*, voici un exemple de fichier chiffré :

```
more lemessage.txt.asc
-----BEGIN PGP MESSAGE-----
Version: GnuPG v1.2.1 (GNU/Linux)
```

```
hQEOA05rfP6vVFXvEAQA182DzoU/qGactJK+T/F1f2VPfGy5HhKEPbxJr53QSd1S
vKtHdZniXmpcRIFDWIFUKZDWjA4pR4v1wUyn6PUI6ud9XXhh6HfZd5sJLub7l6s6
0bHIFFCBlyRTSMq07uqdJD8TNUcezBMrdmu+1fjkQuGu0Qh9w/VNHunGJJJa/JiYD
/0ZN8ifnPNt0UNdh7yWIny4sGPsf7drdx7jtvx6J0Gf0z4Di3HtxHnV50J/rgejb
8lAnUj1UW+KWKnyc3lprGqzt1WmZZKuXV26fyiKTxO8os6wNak7wwcTrjlIm1Kz
OVDsyfN/fVf41+CxxdQbDwVlXPVKKjW5ClZ6kumyivkD0oIBlCOE9qUi219Pzzjo
/IOHnm/JhqX/C/af56yZYyvO12uatj+8kDlfsYjSgTkySkBJ6/xCgseuzPLKV9iW
tnpm3TdljZobM/hIn7/XNSO16TBF0KnpEcZf+eIhw9BqXXfY/aIWlh7GbWsxmvdI
LUmOE3iJ114febjRb9he7WQuXJ3P
=9FKm
-----END PGP MESSAGE-----
```

Un message chiffré peut aussi être signé, pour cela utiliser la commande :

```
gpg -r poil@poil.is-a-geek.net -a -s - -encrypt message.txt
```

Déchiffrement des données

Pour déchiffrer un fichier utiliser la commande :

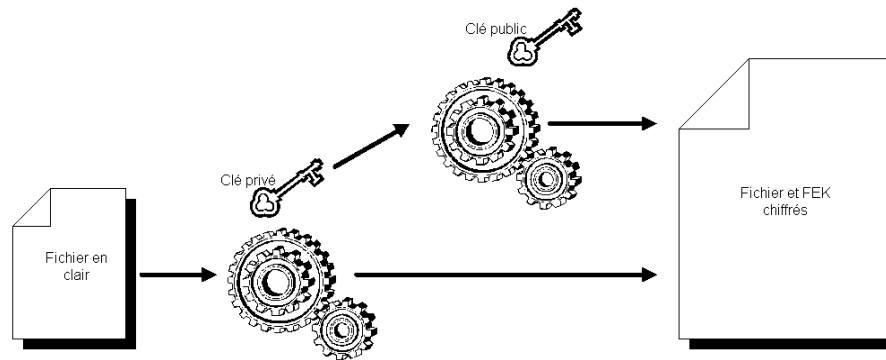
```
gpg - -decrypt message.txt.asc > message.txt
```

Chiffrement du système de fichiers - Windows

Le système de fichiers cryptés (EFS) est disponible depuis Windows 2000. Dans cette section ...

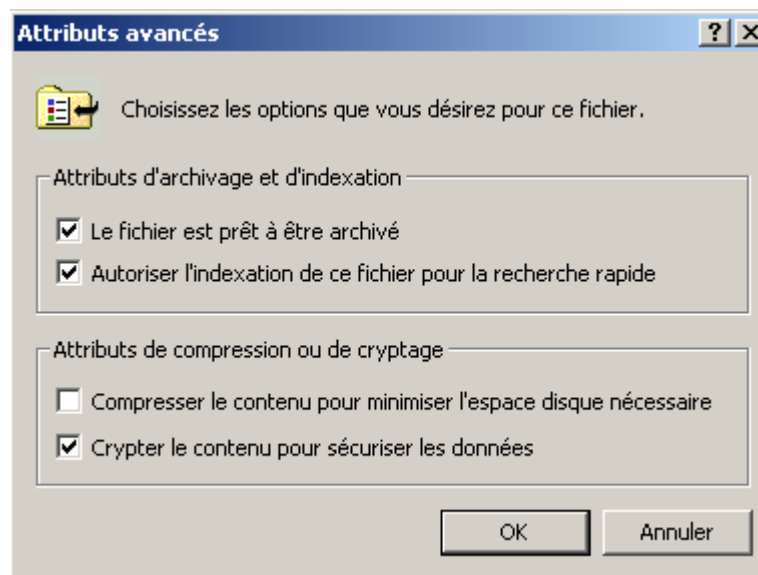
Principe de fonctionnement

Microsoft a choisi de mettre en œuvre à la fois un cryptage par clé privée et un cryptage par clé publique. À la réception d'une requête de cryptage d'un fichier, le système EFS génère un nombre aléatoire pour ce fichier. Ce nombre est la clé de cryptage de fichier (FEK). Cette clé avant d'être stocké sur le disque est chiffrée à l'aide d'une clé publique. La figure suivante représente cet algorithme.



Activation du cryptage de fichier

Pour activer le cryptage de fichiers, aller dans les propriétés du fichier concerné, cliquez bouton droit, puis sur propriétés, ensuite choisissez le bouton avancé et cocher la case crypter "le contenu de ce fichier". (Mettre à jour la figure)



L'utilitaire *cipher*

Vous pouvez utiliser l'utilitaire Cipher.exe pour afficher ou crypter des données à partir d'une fenêtre de commande DOS. Il suffit de taper la commande suivant pour crypter un fichier :

```
cipher [/E | /D] [/S:dir] [/I] [/F] [/Q] [dirname [...]]
```

où *dirname* spécifie un fichier ou répertoire.

Les options disponibles de la commande sont présentées dans le tableau ci-après. Pour afficher ces informations au niveau de l'invite DOS, taper *cipher /?*.

Commutateur	Description
/E	Crypte les répertoires spécifiés. Ceux-ci seront marqués de telle sorte que les fichiers ajoutés après cette opération seront cryptés.
/D	Décrypte les répertoires spécifiés. Ceux-ci seront marqués de telle sorte que les fichiers ajoutés après cette opération ne seront pas cryptés.
/S	Effectue l'opération spécifiée au niveau du répertoire concerné et de tous ses sous-répertoires.
/I	Continue d'effectuer l'opération spécifiée même après la survenance d'erreurs. Par défaut, CIPHER s'arrête lorsqu'une erreur se produit.
/F	Force l'opération de cryptage sur tous les répertoires spécifiés, même si certains d'entre eux sont déjà cryptés. Par défaut, ces derniers sont ignorés.
/Q	Signale uniquement les informations essentielles.

Lorsque *cipher* est employé sans spécifier de paramètres, il affiche l'état de cryptage du répertoire courant et de tous les fichiers qu'il contient.

Chiffrement du système de fichiers - Linux

Dans cette section, le système de chiffrement des données du système de fichiers avec LUKS (Linux Unified Key Setup) est présenté. LUKS est une norme de chiffrement de disque. On peut l'utiliser pour chiffrer une ou plusieurs partition et ainsi améliorer la confidentialité d'un système de fichier.

Installation de TCFS

L'utilisation de LUKS n'étant pas encore très répandu il est préférable avant d'installer LUKS, de créer une partition ext2 vide.

L'installation LUKS est simple, il suffit d'installer les 3 paquetages suivant:

- cryptsetup
- device-mapper
- util-linux

Utilisation de LUKS

À titre d'exemple, la partition /home sera encrypté.

1. Il faut travailler en « runlevel 1 » :

```
telinit 1
```

2. Démontons la partition à chiffrer :

```
umount /home
```

Si cela ne fonctionnait pas, utilisez fuser pour trouver et tuer le processus qui bloque :

```
fuser -mvk /home
```

3. Vérifiez que /home est bien démonté :

```
cat /proc/mounts | grep home
```

4. Remplissez votre partition avec des données aléatoires :

```
dd if=/dev/urandom of=/dev/VG00/LV_home
```

Note: Nous attirons votre attention sur le fait que cette procédure peut prendre plusieurs heures, mais c'est impératif dans le but d'avoir la meilleure protection possible.

5. Initialisez votre partition :

```
cryptsetup --verbose --verify-passphrase luksFormat /dev/VG00/LV_home
```

6. Ouvrez le nouveau volume crypté :

```
cryptsetup luksOpen /dev/VG00/LV_home home
```

7. Vérifiez que le volume est bien ouvert :

```
ls -l /dev/mapper | grep home
```

8. Créez le système de fichier (ext3 dans notre exemple) :

```
mkfs.ext3 /dev/mapper/home
```

9. Montez le nouveau système de fichier :

```
mount /dev/mapper/home /home
```

10. Vérifiez qu'il soit bien visible :

```
df -h | grep home
```

11. Ajoutez le au fichier /etc/crypttab (à créer au besoin). C'est ce fichier qui décrit les périphériques de bloc chiffrés qui sont configurés au démarrage du système. :

```
home /dev/VG00/LV_home none
```

12. Editez votre fichier /etc/fstab, supprimez l'ancienne ligne correspondant à votre /home/ et remplacez la par :

```
/dev/mapper/home /home ext3 defaults 1 2
```

13. Vérifiez l'entrée fstab :

```
mount /home
```

14. Restaurez les contextes SELinux :

```
/sbin/restorecon -v -R /home
```

15. Redémarrez :

```
shutdown -r now
```

Lors du démarrage, votre ordinateur vous demandera votre mot de passe Luks.

Kerberos

La plupart des systèmes de réseau conventionnels utilisent des procédures d'authentification par mot de passe. Dans le cadre d'une telle procédure, les mots de passe des utilisateurs circulent sur le réseau. Malheureusement, la transmission des informations d'authentification pour de nombreux services s'effectue de façon non cryptée. Des utilisateurs non autorisés peuvent donc intercepter des mots de passe qui circulent sur le réseau. Pour qu'une telle procédure soit sécurisée, le réseau doit être inaccessible aux utilisateurs externes, et il est essentiel de pouvoir faire confiance à tous les ordinateurs et utilisateurs sur le réseau.

Kerberos est un protocole d'authentification réseau créé par MIT (1986) qui permet d'éviter la transmission de mots de passe non cryptés à travers le réseau. Lorsque Kerberos est utilisé correctement, il élimine de façon efficace la menace que posent sur un système les renifleurs de paquets.

Deux RFC contiennent une description de Kerberos v5 : RFC 1510 (« *The Kerberos Network Authentication Server (V5)* », septembre 1993) et RFC 1964 (« *The Kerberos Version 5 GSS-API Mechanism* », juin 1995). Windows 2000 et Linux ont mis en œuvre Kerberos en respectant les spécifications établis dans le RFC 1510 et le RFC 1964.

Terminologie Kerberos

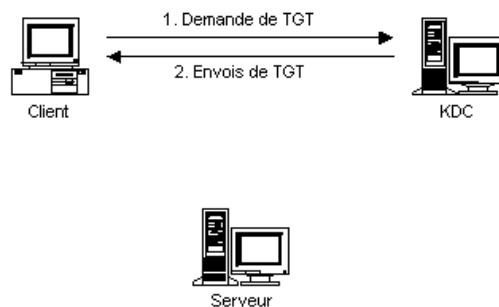
Kerberos dispose de sa propre terminologie pour définir différents aspects du service. Avant d'évoquer la manière dont Kerberos fonctionne, il convient de se familiariser avec les termes suivants:

- **Key Distribution Center (KDC)** : Service émettant des tickets Kerberos.
- **Principal** : Le principal est le nom unique de l'utilisateur ou du service pouvant effectuer une authentification à l'aide de Kerberos. Tous les éléments principaux d'une zone ont leur propre clé dérivée de leur mot de passe ou définie de façon aléatoire pour les services.
- **Ticket** : Ensemble temporaire de certificats indiquant l'identité d'un client pour un service particulier.

- **Ticket d'émission de tickets (*Ticket Granting Ticket, TGT*)** : Ticket spécial permettant au client d'obtenir des tickets supplémentaires sans les demander au KDC.

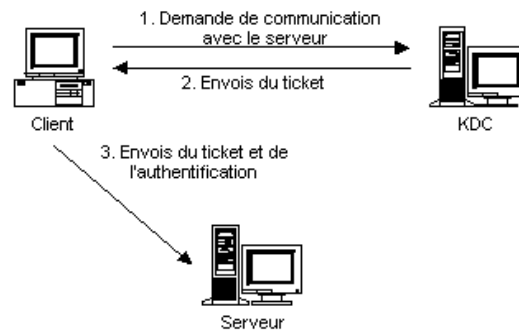
Fonctionnement de Kerberos

Kerberos est différent des autres méthodes d'authentification. Plutôt que de laisser l'authentification avoir lieu entre chaque machine et chaque serveur, Kerberos utilise un centre distributeur de tickets (KDC, Key Distribution Center) afin d'authentifier les utilisateurs sur un réseau. Une fois l'authentification effectuée, Kerberos stocke un ticket spécifique à cette session sur l'ordinateur de l'utilisateur et les services réseau rechercheront ce ticket au lieu de demander à l'utilisateur de s'authentifier à l'aide d'un mot de passe.



Lorsqu'un utilisateur se connecte sur son poste de travail, son principal est envoyé au KDC comme une demande de TGT. Cette demande peut être émise par le programme de connexion de sorte qu'elle est transparente pour l'utilisateur. Le KDC vérifie la présence du principal dans sa base de données. Si le principal y figure, le KDC crée un TGT, le crypte à l'aide de la clé de l'utilisateur, puis le renvoie à ce dernier.

Chaque fois que l'utilisateur doit accéder à un service réseau, le logiciel client utilise le TGT pour demander au KDC un nouveau ticket pour ce service spécifique. Le ticket pour le service souhaité est alors émis et utilisé pour authentifier l'utilisateur auprès de ce service de façon transparente.



Configuration d'un serveur Kerberos 5 – Windows

Depuis Windows 2000, le KDC est mis en œuvre comme protocole d'authentification par défaut. La base de données de comptes nécessaire au KDC est incluse dans Active Directory.

Configuration d'un serveur Kerberos 5 – Linux

Ce référé à la documentation de Ubuntu.

Références

Stefen Norberg, « Securing Windows NT/2000 Servers for the Internet », O'Reilly, 2001.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.

« Red Hat Linux 9 : Red Hat Linux Security Guide », Red Hat Inc., 2002.

« Red Hat Linux 9 : Guide de référence Red Hat ». Red Hat Inc., 2003.

Simon Guillem-Lessard, « Cryptographie Tutorial », Projet de fin d'étude, Université du Québec à Trois-Rivières, 2002.